

PurposeSeal

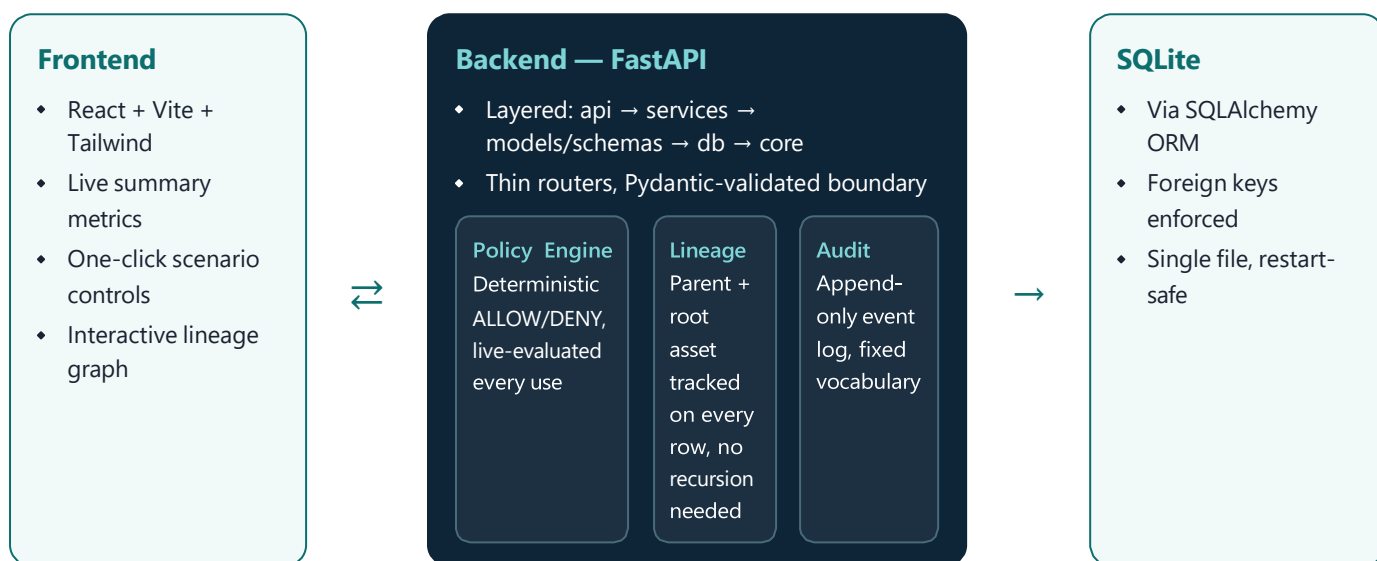
Purpose-Bound Access Lifecycle Enforcement — Architecture & Workflow Overview

1 What This Is

The problem: access-control systems stop at the front door — they check whether someone may *retrieve* data for a bounded purpose, but once that data is retrieved, revoking or expiring the grant does nothing to the copies, exports, and derivatives that already exist. A researcher granted clinical-trial access can keep using — or misuse — the exported data long after the trial's purpose window closes, and no access-control check on the original grant will ever catch it.

The solution: PurposeSeal enforces the purpose itself, continuously, not just the access grant at the moment of retrieval. Every retrieval and every subsequent copy or derivative carries its originating grant's identity forward as a **purpose seal**. Every attempted *use* of that data — not only its retrieval — is evaluated live against that seal. A violation quarantines the offending copy and creates a persisted remediation record, while the original source data and unrelated copies stay untouched.

2 Architecture



3 Workflow — How a Violation Is Detected

- 1 **Grant** — a purpose-bound authorization is issued: who, why, over what asset, for how long, for which operations.
- 2 **Retrieve** — the actor pulls the data under that grant; a new purpose-sealed copy is created and linked to the grant.
- 3 **Propagate purpose** — the seal is inherited, by reference, by every subsequent copy or derivative — never duplicated as a stale value.
- 4 **Copy** — an exact copy or transformed derivative is made; it always inherits its root and origin grant from its parent.
- 5 **Expire** — the grant's validity window closes (simulated instantly via a controlled clock for demo purposes).
- 6 **Continued-use attempt** — someone tries to reuse the already-retrieved data: past expiry, for a different purpose, or after explicit revocation.
- 7 **Policy decision** — the engine re-evaluates fresh, every time: actor, purpose, operation, live grant status → **ALLOW** or **DENY** with an exact reason code.
- 8 **Remediation** — a purpose-lifecycle violation quarantines the offending copy and persists a remediation record: reason, corrective action, review status.
- 9 **Audit** — every step above writes an immutable event, forming one complete, queryable timeline per asset or grant.

The key mechanism: detection never depends on the grant still existing. The policy engine re-checks the purpose seal live, at the moment of *use* — so revoking or expiring a grant is not what catches misuse; re-evaluating every subsequent use against it is.

4 Extra Features Beyond the Original Brief

Full web dashboard

Only a "convincing demonstration" was required — a complete live dashboard was built instead of a script or raw API calls.

Interactive lineage graph

Click any node in a data's provenance tree to see its parent, root, grant, purpose, expiry, status, and fingerprint.

Role-aware authentication

Five roles, kept strictly separate from purpose authorization — being logged in never implies a use is purpose-valid.

SHA-256 fingerprinting

Supporting provenance evidence for exact copies, with its real limitations (can't detect transformed content) stated explicitly.

Persistent remediation workflow

Every violation gets a structured record — reason, corrective action, review status — not just a logged denial.

Idempotent, RBAC-gated revocation

An explicit revoke endpoint, safe to call repeatedly, restricted to Compliance Officer/Admin roles.

Deterministic one-call demo scenarios

Built so a live judged demo can be re-run indefinitely with zero timing dependencies or manual setup.

Reliability hardening pass

A dedicated review that found and fixed real bugs (e.g. a quarantined asset that could still be copied) before they reached a live demo.

End-to-end test suite, measured coverage

165 backend + 24 frontend tests; 97% line coverage measured with pytest-cov, not assumed.

Consistent API error contract

Every error — including validation failures — returns the same clean shape, never a leaked stack trace.

Screenshots:

PurposeSeal

Purpose-bound access lifecycle enforcement

● Backend connected

Grants

Retrieved Data

Audit Trail

SUMMARY

Active Grants

1

Tracked Copies

39

Violations Detected

0

this session

Quarantined Assets

8

SCENARIO CONTROLS

Run Valid Scenario

Run Expired-Purpose Scenario

Run Purpose-Mismatch Scenario

RESULT

Run a scenario above to see the result here.

JOURNEY TIMELINE

Run a scenario above to see its journey timeline here.

For valid scenario:

SCENARIO CONTROLS

Run Valid Scenario

Run Expired-Purpose Scenario

Run Purpose-Mismatch Scenario

RESULT

ALLOW

WHY?

Use is within the grant's active window, matches its original purpose, and the operation is permitted.

ORIGINAL PURPOSE

clinical_trial_screening

REQUESTED PURPOSE

clinical_trial_screening

EXPIRY

9/6/2026, 3:05:56 PM

ASSET

analysis_dataset_1 (Legitimate Use Demo) (#62)

REMEDATION STATUS

N/A

CORRECTIVE ACTION

No action needed — this use is fully within its authorized purpose and validity window.

DATA LINEAGE

+

-

↺

Patient Lab Result #104 (Legitimate Use Demo)
ACTIVE

Retrieved copy of Patient Lab Result #104 (Legitimate Use Demo)
ACTIVE

analysis_dataset_1 (Legitimate Use Demo)
ACTIVE

ASSET

Retrieved copy of Patient Lab Result #104 (Legitimate Use Demo) (#61)

PARENT

#60

ROOT

#60

ASSOCIATED GRANT

#21

ORIGINAL PURPOSE

clinical_trial_screening

EXPIRY

9/6/2026, 3:05:56 PM

STATUS

ACTIVE

FINGERPRINT

dafb18fd5222...

For expired purpose scenario:

Active Grants
1

Tracked Copies
43

Violations Detected
1
this session

Quarantined Assets
9

SCENARIO CONTROLS

Run Valid ScenarioRun Expired-Purpose ScenarioRun Purpose-Mismatch Scenario

RESULT

BLOCKED

WHY?

The purpose grant authorizing this data expired at 2026-09-06T09:16:42.994962+00:00 and was evaluated at 2026-09-06T09:17:43.040812+00:00.

ORIGINAL PURPOSE

clinical_trial_screening

REQUESTED PURPOSE

clinical_trial_screening

EXPIRY

9/6/2026, 2:46:42 PM

ASSET

analysis_dataset_1 (Purpose Expiry Demo) (#65)

REMEDATION STATUS

COMPLIANCE_REVIEW_REQUIRED

CORRECTIVE ACTION

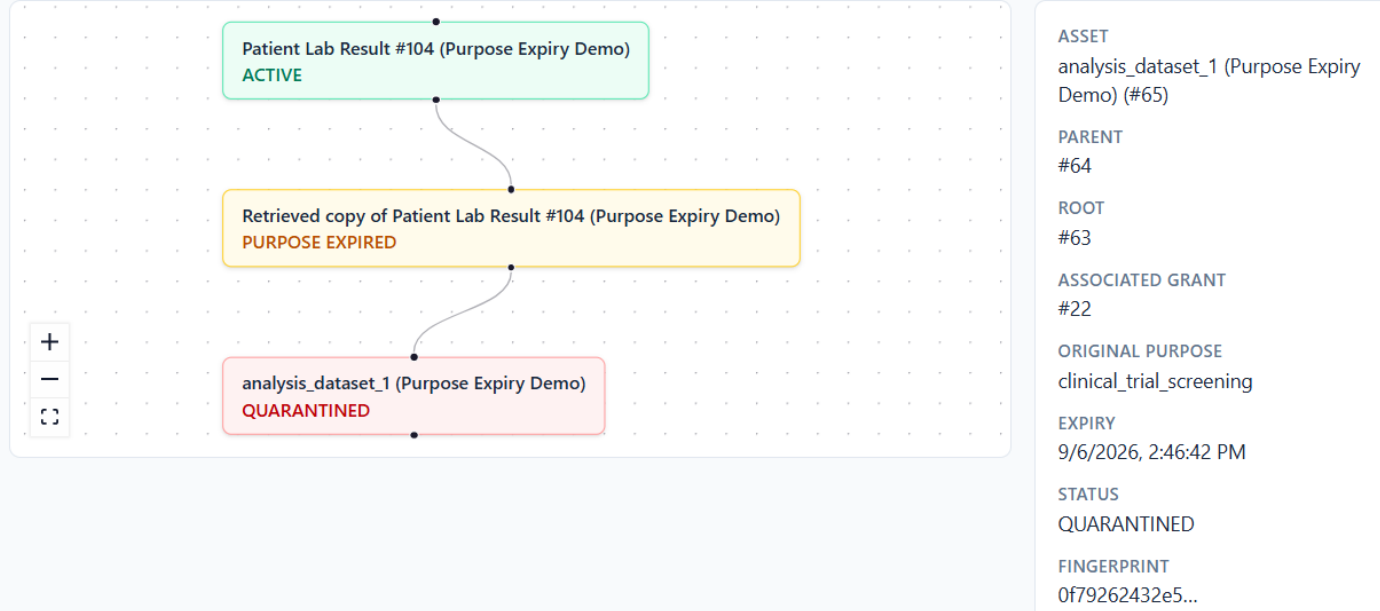
Issue a new purpose grant against the original asset if continued access is legitimate; this asset remains quarantined under its expired grant.

● Purpose Expired — Violation Detected
9/6/2026, 2:47:43 PM

● Asset Quarantined
9/6/2026, 2:47:43 PM

● COMPLIANCE_REVIEW_REQUIRED
9/6/2026, 2:47:43 PM

DATA LINEAGE



For purpose mismatch scenario:

SUMMARY

Active Grants

2

Tracked Copies

44

Violations Detected

2

this session

Quarantined Assets

10

SCENARIO CONTROLS

Run Valid Scenario

Run Expired-Purpose Scenario

Run Purpose-Mismatch Scenario

RESULT

BLOCKED

WHY?

This data was retrieved for 'clinical_trial_screening', not 'marketing_analytics'.

ORIGINAL PURPOSE

clinical_trial_screening

REQUESTED PURPOSE

marketing_analytics

EXPIRY

9/6/2026, 3:18:37 PM

ASSET

Retrieved copy of Patient Lab Result #104 (Purpose Mismatch Demo) (#67)

REMEDIATION STATUS

COMPLIANCE_REVIEW_REQUIRED

CORRECTIVE ACTION

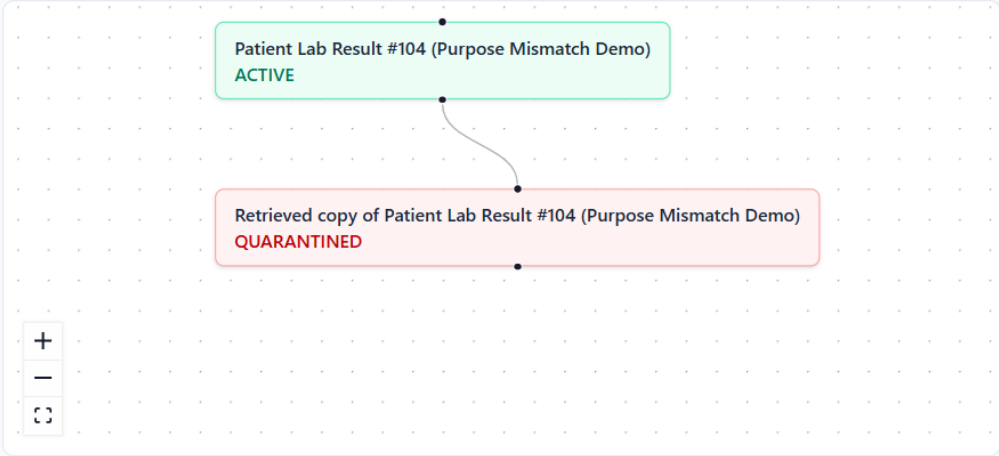
If this new purpose is a legitimate use case, issue a new purpose grant for it against the original asset; this asset remains quarantined under its original grant's purpose.

● Purpose Mismatch — Violation Detected
9/6/2026, 2:48:37 PM

● Asset Quarantined
9/6/2026, 2:48:37 PM

● COMPLIANCE_REVIEW_REQUIRED
9/6/2026, 2:48:37 PM

DATA LINEAGE



ASSET
Retrieved copy of Patient Lab Result
#104 (Purpose Mismatch Demo)
(#67)

PARENT
#66

ROOT
#66

ASSOCIATED GRANT
#23

ORIGINAL PURPOSE
clinical_trial_screening

EXPIRY
9/6/2026, 3:18:37 PM

STATUS
QUARANTINED